Комплексні системи захисту інформації

Експерт Українського науково-дослідного інституту спеціальної техніки та судових експертиз СБУ
к.т.н. Пірог Олександр Вікторович

Тема 1. Концепція інформаційної безпеки

Питання:

- Інформаційна безпека (InfoSec).
- Види інформаційної безпеки.
- Елементи ІБ.
- Основні положення системи захисту інформації (СЗІ).
- Вимоги безпеки СЗІ.
- Умови безпеки СЗІ.
- Види забезпечення безпеки СЗІ
- Моделі інформаційної безпеки, їх основні компоненти.
- Основні компоненти інформаційної безпеки.
- Загрози інформації та їх прояви.
- Конфіденційність.
- Цілісність.
- Доступність.
- Суб'єкти системи ТЗІ.
- Поверхня, вектор, дерево атаки.
- Модель глибинної (багатошарової) оборони.
- Ланцюжок кібервбивства (Cyber Kill Chain)
- Сімейства елементів керування безпекою (NIST)
- Технології захисту інформації.
- Управління рівнем безпеки (SLM).
- Цикл Демінга (PDCA).

Література:

- Козюра В.Д. Комплексні системи захисту інформації в інформаційно-телекомунікаційних системах: Навчальний посібник / В.Д.Козюра, В.О.Хорошко, М.Є.Шелест, Ю.М.Ткач, Я.Ю.Усов. – Ніжин: ТПК «Орхідея», 2019. – 144 с.
- Гарасимчук О.І., Дудикевич В.Б., Ромака В.А. Комплексні системи санкціонованого доступу: навч. посібник / О.І.Гарасимчук, В.Б.Дудикевич, В.А.Ромака – Л. : Вид-во Львів. політехніки, 2010. - 212 с.
- Блавацька Н.М. Програмне забезпечення систем захисту інформації : підручник / Н.М.Блавацька, В.Д.Козюра, В.О.Хорошко. – К.: Вид. ДУІКТ, 2011. – 330 с.
- Коженевский С.Р. Термінологічний довідник з питань технічного захисту інформації / С.Р.Коженевский, Г.В.Кузнецов, В.О.Хорошко, Д.В.Чирков; за ред. проф. В.О.Хорошка. – К.: Вид. ДУІКТ, 2007. – 365с.

Принципи / моделі загроз:

- CIA.
- STRIDE (Microsoft).
- LINDDUN.

CIA:

- Конфіденційність (Confidentiality).
- Цілісність (Integrity).
- Доступність (Availability).

НД ТЗІ:

- Конфіденційність.
- Цілісність.
- Доступність.
- Спостережність і керованість.

STRIDE (Microsoft):

- Підміна особистості (Spoofing),
- Підробка даних (Tampering),
- Відмова від транзакцій (Repudiation),
- Розкриття інформації (Information disclosure),
- Відказ в обслуговуванні (Denial of Service),
- Підвищення привілеїв (Elevation of Privilege).

LINDDUN

- Пов’язування (Linkability) (зловмисник може пов’язати два об’єкти не ідентифікуючи їх),
- Ідентифікованість (Identifiability) (зловмисник може ідентифікувати суб’єкта),
- Неможливість відмови (Non-Repudiation) (суб’єкт не може відмовити в претензії),
- Виявлення (Detectability) (Зловмисник знає чи існує об’єкт),
- Розкриття інформації (Disclosure of Information),
- Необізнаність (Unawareness),
- Невідповідність законодавству (Non-Compliance)

Концептуальна модель безпеки інформації

ЗАГРОЗИ ІНФОРМАЦІЇ

***Загроза* — будь-які обставини або події, що можуть бути причиною порушення політики безпеки інформації і/або нанесення збитків ІС.**

***Атака* — спроба реалізації загрози.**

Проявляється в порушенні

Конфіденційності

Неправомірний доступ к ІзОД:
- розголошування;
- витік;
- НСД.

Цілісності

Умисне перетворення даних, що містяться в ІС:
- спотворення;
- помилка;
- втрата;
- підробка;

Доступності

Повна або тимчасова неможливість отримання доступу до ресурсів ІС:
- захоплення ресурсів;
- блокування доступу;
- знищення ресурсів

Спостереженості

Порушення можливості ІС фіксувати діяльність користувачів і процесів, використання об'єктів
Порушення:
- аудиту;
- ідентіфікації і автентифікації;
- розподілу обов'язків;
- цілісністі КЗЗ

Загрози та їх прояви

Конфіденційність

Інформація:

- Відкрита.
- З обмеженим доступом:
  - Конфіденційна,
  - Таємна,
  - Службова.

Типи конфіденційної інформації:

- Персональна.
- Комерційна.
- Судово-слідча.

Типи персональних даних (Personally Identifiable Information, PII):

- Ідентифікаційні.
- Медичні.
- Фінансові.
- Інші конфіденційні.

Закон України «Про інформацію»

Концепція ААО (англ. ААА) :

- Аутентифікація (Authentication).
- Авторизація (Authorization).
- Облік (Accounting).

Авторизація

Користувач JohnS авторизувався

Користувач JohnS запитує доступ до File01

User = JohnS
Group = Admin

Затверджено

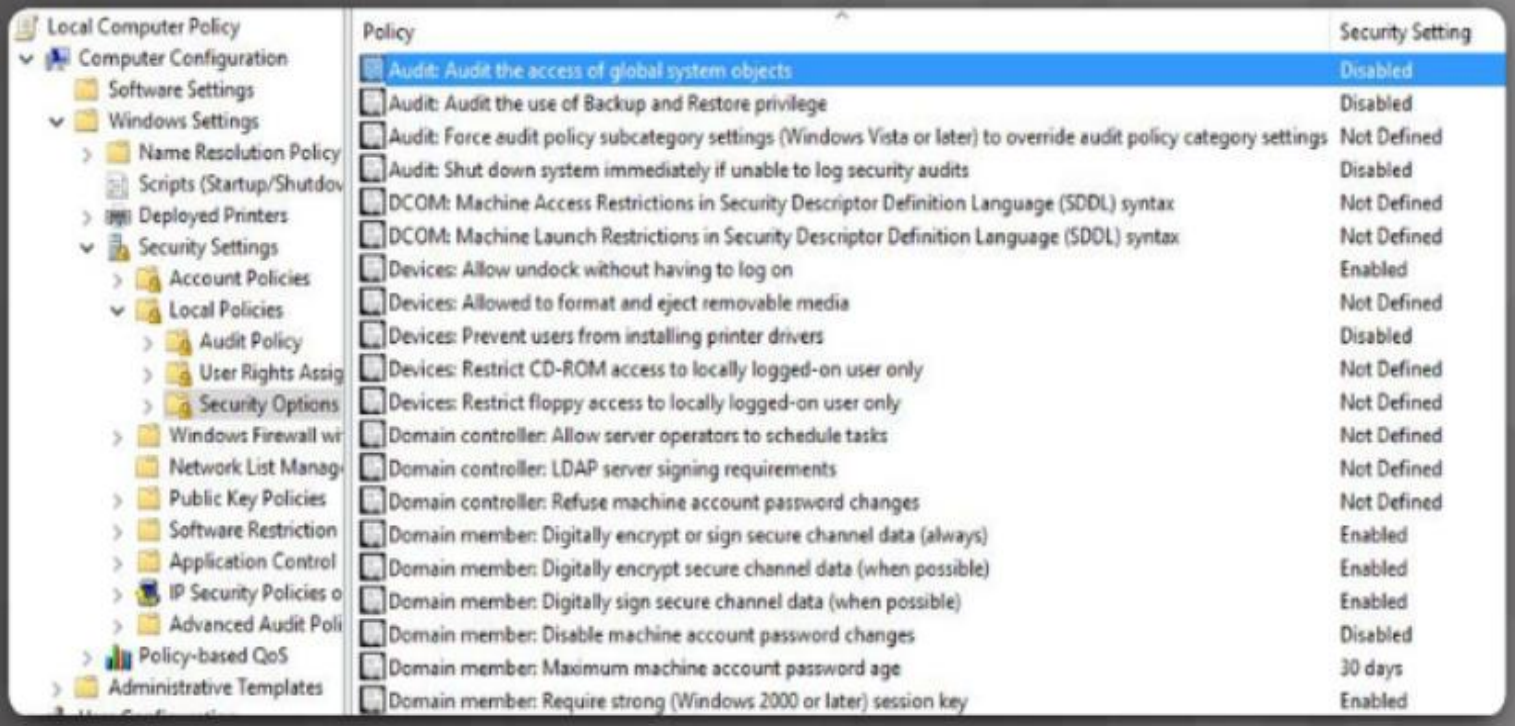
Доступ до Читання/Зміни/Виконання надано.

Admin Group

User JohnS

	Власник	Група	Усі
File01	R W X	R W -	R--
File02	R W X	R W -	R--

Облік


Local Computer Policy
Computer Configuration
Software Settings
Windows Settings
Name Resolution Policy
Scripts (Startup/Shutdov
Deployed Printers
Security Settings
Account Policies
Local Policies
Audit Policy
User Rights Assig
Security Options
Windows Firewall wi
Network List Manag
Public Key Policies
Software Restriction
Application Control
IP Security Policies o
Advanced Audit Poli
Policy-based QoS
Administrative Templates
Policy
Security Setting
Audit: Audit the access of global system objects
Disabled
Audit: Audit the use of Backup and Restore privilege
Disabled
Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings
Not Defined
Audit: Shut down system immediately if unable to log security audits
Disabled
DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax
Not Defined
DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax
Not Defined
Devices: Allow undock without having to log on
Enabled
Devices: Allowed to format and eject removable media
Not Defined
Devices: Prevent users from installing printer drivers
Disabled
Devices: Restrict CD-ROM access to locally logged-on user only
Not Defined
Devices: Restrict floppy access to locally logged-on user only
Not Defined
Domain controller: Allow server operators to schedule tasks
Not Defined
Domain controller: LDAP server signing requirements
Not Defined
Domain controller: Refuse machine account password changes
Not Defined
Domain member: Digitally encrypt or sign secure channel data (always)
Enabled
Domain member: Digitally encrypt secure channel data (when possible)
Enabled
Domain member: Digitally sign secure channel data (when possible)
Enabled
Domain member: Disable machine account password changes
Disabled
Domain member: Maximum machine account password age
30 days
Domain member: Require strong (Windows 2000 or later) session key
Enabled

Використання кредитної картки

Аутентифікація
Хто Ви?

Авторизація
Скільки ви можете витратити?

Облік
Що ви витратили?

Account Number	Statement Closing Date	Current Amount Due
1234-567-890	01-31-01	$278.50

MAIL PAYMENT TO:

JOE EMPLOYEE
456 SKYVIEW DRIVE
HOMETOWN, USA 99900-1234

THE BANK
132 VINE STREET
ANYTOWN, USA 67500-6010

872919345 00178255000000003

Detach here and return upper portion with check or money order. Do not staple or fold.

Statement of Personal Credit Card Account

Retain this portion for your files.

THE BANK

Cardmember Name	Account Number	Statement Closing Date
JOE EMPLOYEE	1234-456-890	01-31-01

Statement Date:	02-01-01	Payment Due Date:	03-01-01
Closing Date:	01-31-01		
Credit Limit	$1,500.00	Credit Available:	$1221.50
New Balance:	$278.50	Minimum Payment Due:	$20.00

Account Summary

Previous Balance:	+74.24	Transaction Fees:	+3.00
Purchases:	+250.50	Annual Fees:	+25.00
Cash Advances:	+0	Current Amount Due:	+250.50
Payments:	-74.25	Amount Past Due:	+0
Finance Charge:	+0	Amount Over Credit Line:	+0
Late Charge:	+0	NEW BALANCE:	$278.50

Reference Number	Sold	Posted	Activity Since Last Statement		Amount
43210987	01-03	01-13	Payment, Thank You		-$74.25
01234567	01-12	01-13	Wings 'N' Things	Anytown, USA	$25.25
78901234	01-14	01-17	Record Release	Anytown, USA	$40.00
45678901	01-14	01-17	Sports Stadium	Anytown, USA	$75.25
3210987	01-22	01-23	Tie Tack	Anytown, USA	$20.75
76543210	01-29	01-30	Electronic World	Anytown, USA	$89.25
23455678		01-30	Transaction Fees		$3.00
34567890		01-01	Annual Fee		$25.00

PAGE 1 OF 1

Дії, які призводять до незаконного оволодіння ІзОД:

- *розголошення* – умисні або необережні дії осіб, яким відомості були довірені, що привели до ознайомлення з ними осіб, не допущених до них;
- *витік* – безконтрольний вихід ІзОД за межі організації або кола осіб, яким вона була довірена;
- *несанкціонований доступ* – протиправне умисне оволодіння ІзОД особою, яка не має права доступу до відомостей.

Технічний канал витоку інформації – це фізичний шлях від джерела конфіденційної інформації до зловмисника, за допомогою якого він може отримати доступ до відомостей, що охороняються.

По фізичній природі можливі наступні шляхи перенесення інформації:

- звукові хвилі;
- світлові промені;
- електромагнітні хвилі,
- матеріали і речовини.

Типи технічних каналів витоку інформації:

- акустичні канали (звукові коливання в будь-якому середовищі);
- оптичні канали (електромагнітні випромінювання в інфрачервоній, видимій і ультрафіолетовій частині спектру);
- радіоканали (електромагнітні випромінювання радіодіапазону);
- електричні канали (небезпечна напруга і струми в струмопровідних комунікаціях);
- матеріально-речові канали (папір, фото, цифрові і магнітні носії, відходи і т.п.).

Цілісність

Цілісність це:

- точність,
- узгодженість,
- достовірність.

Потреба в цілісності:

- Критичний рівень (медичні).
- Високий (комерція).
- Середній (пошукові системи).
- Низький (блоги).

Перевірка цілісності:

- Резервні копії.
- Хеш-функція, контрольна сума:
  - MD5,
  - SHA-1,
  - SHA-256,
  - SHA-512.

Доступність

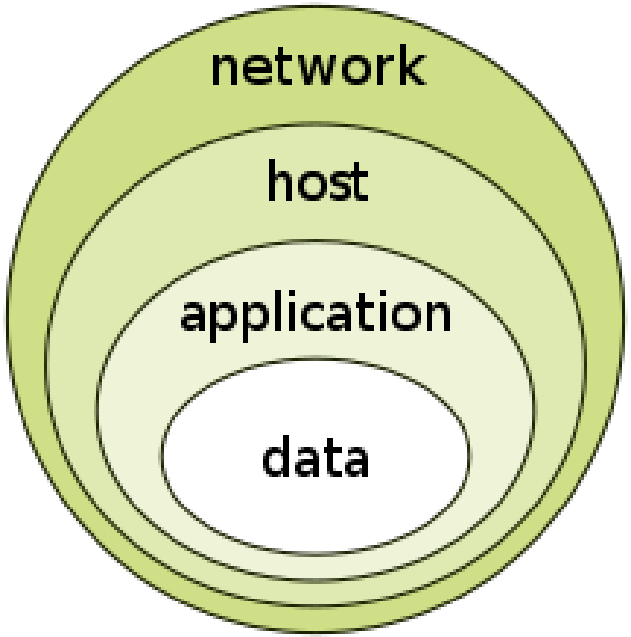
Загрози доступності:

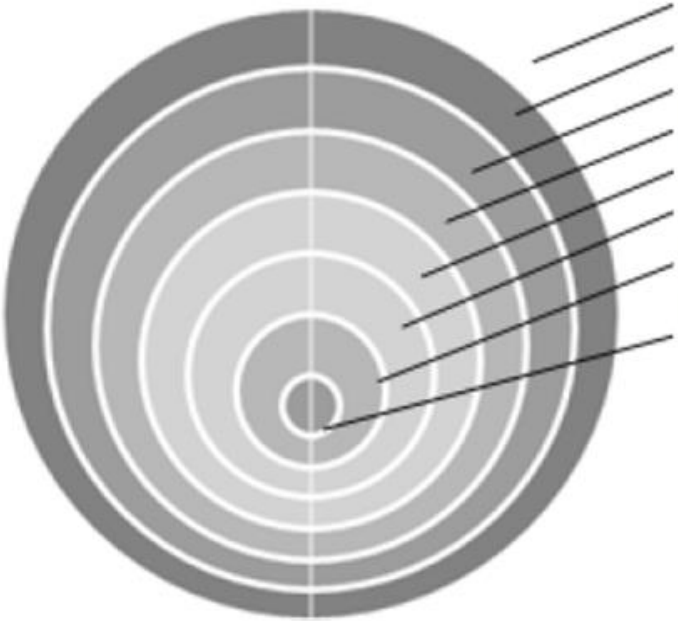
- Стихійні лиха.
- Переривання утиліт (живлення, вентиляції).
- Людська помилка.
- Страйки, прогули.
- Саботаж (backdoor, черв’як).
- Кібератаки (віруси, черв’яки, DoS-атаки).
- Помилки ПЗ.
- Крадіжка АЗ.
- Соціально-політичні (теракт, війна).
- Компрометація адміністратора.
- Втрата інформації.
- Пошкодження/відмова ПЗ/АЗ.

Методи забезпечення доступності:

- усунення окремих точок відмови,
- системне резервування,
- підвищена відмовостійкість,
- стандартизація,
- кластеризація,
- тестування,
- технічне обслуговування (Maintenance),
- моніторинг,
- оновлення ОС та ПЗ (Update),
- резервне копіювання (Backup),
- плани аварійного відновлення (Disaster Recovery Plan, DRP).

Модель глибинної (багатошарової) оборони
(Onion model of defense in depth)



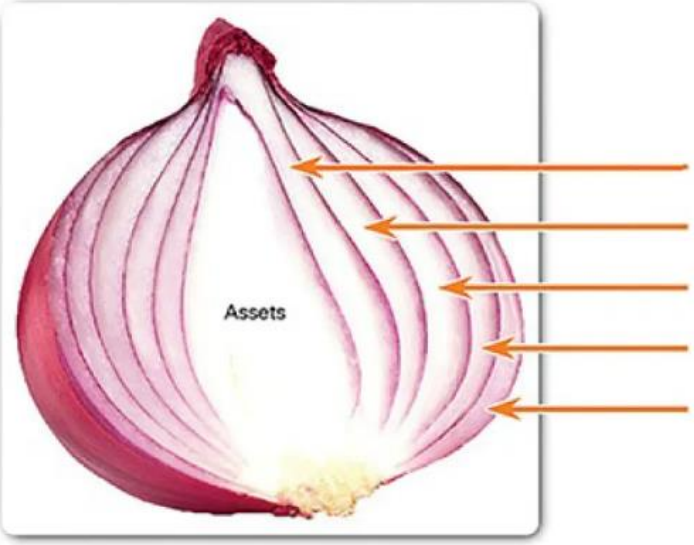


Зовнішня зона (неконтрольована)

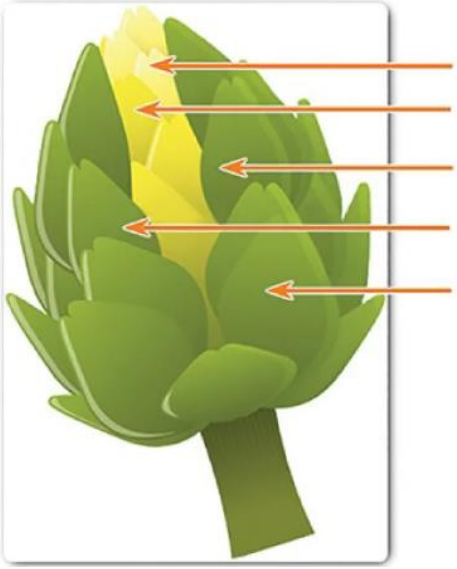
1. Охорона території
2. Охорона будівлі
3. Охорона приміщення
4. Захист ліній зв’язку
5. Захист апаратних засобів
6. Захист програмних засобів
7. Захист інформації

Модель глибинної (багатошарової) оборони
(Onion model of defense in depth)

Цибулина безпеки



Артишок безпеки



Ланцюжок кібервбивства (Cyber Kill Chain):

1. Розвідка (Reconnaissance)
2. Озброєння (Weaponization)
3. Доставка (Delivery)
4. Експлуатація (Exploitation)
5. Встановлення (Installation)
6. Управління та консоль (Command & Control - CnC)
7. Дія по цілям (Action on Objective)

Сімейства елементів керування безпекою (NIST):

- Контроль доступу.
- Обізнаність і навчання.
- Аудит і звітність (журналювання).
- Оцінка, дозвіл та моніторинг.
- Управління конфігураціями.
- Планування на випадок надзвичайних ситуацій (Contingency Planning, CP).
- Ідентифікація та авторизація.
- Індивідуальна участь (PII).
- Реагування на інциденти.
- Технічне обслуговування.
- Захист медіа (носіїв: дискети, жорсткі диски, флеш-накопичувачі, компакт-диски).
- Фізичний захист та захист від навколишнього середовища (захист систем, будівель та інфраструктури).
- Планування (System security plan, SSP).
- Управління безпекою.
- Безпека персоналу (інсайдери).
- Оцінка ризиків.
- Придбання систем і послуг (життєвий цикл системи SDLC).
- Захист систем і комунікацій.
- Цілісність систем та інформації.

Технології захисту інформації:

- Аутентифікація (Authentication).
- Контроль доступу (Access Control).
- Списки контролю доступу (Access control list, ACL)
- Шифрування (Encryption).
- Резервне копіювання (Backups).
- Фізична безпека (Physical Security).
- Поведінкова аналітика користувачів (User behavior analytics, UBA).
- Блокчейн кібербезпека (Blockchain cybersecurity).
- Безпека кінцевих точок (Endpoint detection and response, EDR) (Microsoft Defender, McAfee, ESET, Kaspersky).
- Керування хмарною безпекою (Cloud security posture management, CSPM).

Технології захисту інформації:

- Антивіруси (Antivirus, AV, Next-Generation Antivirus, NGAV).
- Міжмережеві екрани (брандмауери, Firewall, Web Application Firewall, WAF).
- Заміна мережної адреси (Network Address Translation, NAT).
- Заміна адрес портів (Port Address Translation, PAT).
- Балансування навантаження.
- Log-сервер (Syslog, Apache, Microsoft IIS).
- Повне захоплення пакетів (Wireshark).
- Статистичні дані (Cisco NetFlow).
- Фільтри вмісту (Cisco Email/Web Security Appliance, ESA/WSA).
- Proxy-сервер, (Squid, CCProxy, Apache Traffic Server, WinGate).
- Запобігання втраті даних (Data loss prevention, DLP) (McAfee, Symantec).
- Система виявлення вторгнень (Intrusion detection system, IDS, HIDS, NIDS, Protocol-based IDS, PIDS, Application protocol-based, APIDS, Anomaly-based) (HIDS: OSSEC, NIDS: Snort (правила), Bro (поведінка), Suricata (сигнатури)).
- Система запобігання вторгненням (Intrusion protection system, IPS) (Cisco NGIPS).
- Керування інцидентами та подіями безпеки (Security incident and event management, SIEM) (Sguil, Enterprise Log Search and Archive, ELSA, AlienVault USM, IBM QRadar).

Тема 2. Комплексна система захисту інформації

Питання:

- Комплексна система захисту інформації (КСЗІ).
- Цілі та завдання КСЗІ.
- Правові заходи безпеки.
- Організаційні заходи безпеки.
- Методологія розробки політики безпеки.
- Класифікація активів.
- Об’єкти захисту.
- Стани даних.
- Суб’єкти інформаційних відносин.
- Класифікація порушників та їх мотиви.
- Класифікація загроз.
- Способи обробки ризиків.
- Якісний / кількісний аналіз ризиків.
- Управління ризиками (NIST)
- Політики безпеки.
- Основні складові політики безпеки (NIST)
- Вимоги безпеки СЗІ.
- Склад КСЗІ.
- Принципи створення КСЗІ.
- Основні вимоги до КСЗІ.

Комплексна система захисту інформації (КСЗІ) – це сукупність

- правових,
- організаційних,
- інженерних заходів,
- програмно-апаратних,
- криптографічних,
- інших засобів,

які забезпечують захист інформації обмеженого доступу в ІТС.

Правові документи
Відомчі документи
Нормативні документи
Конституція
Положення
Інструкції
Накази
Розпорядження
Міжвідомчі накази
Закони
Міністерство юстиції
Кодекси
НД ТЗІ
ДСС ЗЗІУ
СБУ
Укази Президента
Рішення РНБО
Доктрина
Стратегія
Концепція
Положення
Галузеві стандарти
НБУ
Стандарти: міжнародні (ISO/IEC) та національні (ГОСТ, BS)
Державні стандарти (ДСТУ)
Постанови Уряду
Держспоживстандарт

Правові заходи безпеки:

- Законодавство.
- Стандарти (ISO).
- Методичні рекомендації (NIST, NSA, US-CERT, CVE).
- Накази по підприємству.
- Угоди про конфіденційність з працівниками (Non-disclosure Agreement, NDA).
- Вимоги безпеки в угодах з іншими організаціями (контрагентами).
- Угода про рівень послуг (Service-Level Agreement, SLA).
- Угода про нерозголошення персональних даних (Personally Identifiable Information, PII NDA).
- Договір оферти.
- Функціональні (посадові) обов’язки.
- Політики безпеки.
- Затверджені процедури.
- План захисту інформації.
- План безперервності бізнесу (Business Continuity Planning, BCP).
- План аварійного відновлення (Disaster Recovery Plan, DRP).

Організаційні заходи безпеки:

- Розподіл повноважень та обов’язків.
- Обізнаність при прийомі на роботу.
- Перевірка біографії.
- Роз’яснювальна робота.
- Тренінги / курси.
- Періодичне тестування (перевірки та ревізії):
  - Обізнаності персоналу.
  - Виконання політики безпеки.
  - Системи захисту.
  - Системи відновлення.
- Дисциплінарний процес.
- Анулювання прав доступу при припиненні обов'язків.
- Повернення активів.
- Обмеження доступу на об'єкт і до ресурсів АС.
- Розмежування доступу до ресурсів АС.
- Регламентації доступу до ресурсів АС:
  - сторонніх користувачів,
  - власних користувачів.
- Режимні заходи на об’єктах АС.
- Фізичний захист обладнання, носіїв інформації, ресурсів.
- Профілактичні заходи (попередження ненавмисних дій, появи вірусів).
- Обстеження середовищ функціонування АС.
- Сертифікація засобів ЗІ.
- Ліцензування діяльності по ЗІ;
- Атестація об'єктів захисту;
- Взаємодія з питань ЗІ з іншими суб’єктами ТЗІ.
- Розслідування інцидентів безпеки.
- Оцінка ефективності функціонування системи ЗІ.
- Модернізація АС.

Методологія розробки політики безпеки:

1. Визначення активів.
2. Визначення та класифікація можливих порушників.
3. Визначення та класифікація можливих вразливостей та загроз.
4. Оцінка ймовірності та впливу загроз та ризиків.
5. Визначення контрзаходів:
   - правові;
   - організаційні;
   - технічні.
6. Збалансування впливу загроз на вартість контрзаходів.
7. Документальне оформлення політики безпеки.

Класифікація активів (Assets):

1) Визначення активів (ідентифікація, інвентаризація):
   - Інформаційні:
     - технічна та технологічна,
     - ділова та економічна,
     - про службу безпеки підприємства,
   - Програмні.
   - Фізичні/апаратні.
   - Людські.
2) Підзвітність (власники).
3) Критерії класифікації:
   - Конфіденційність,
   - Вартість,
   - Права доступу.
4) Впровадження.

Закон України «Про захист інформації в інформаційно-телекомунікаційних системах»

Об’єкти захисту в ІТС:

- інформаційні ресурси обмеженого доступу та інші інформаційні ресурси, що підлягають захисту від НСД, в тому числі такі, що містять відкриту інформацію;
- процеси обробки інформації в ІТС;
- інфраструктура ІТС – системи обробки інформації, технічні та програмні засоби, канали обміну, системи та засоби захисту інформації, об’єкти та приміщення, в яких розміщено компоненти ІТС;
- користувачі і обслуговуючий персонал ІТС.

Захисту підлягає вся інформація, що може циркулювати в ІТС:

- відкрита інформація (її цілісність та доступність);
- ІзОД, (захист від несанкціонованого та неконтрольованого ознайомлення, модифікації, знищення, копіювання, поширення);
- конфіденційна інформація;
- персональні дані;
- службова інформація;
- інформація, що становить державну таємницю.

Стани даних:

1) Дані в стані спокою або зберігання:
- DAS (пряме сховище).
- RAID, NAS, SAN.
- Cloud (хмарні).

2) Дані в передачі:
- Змінні носії.
- Дротові мережі.
- Бездротові мережі.

3) Дані в обробці:
- Ручне введення.
- Сканування.
- Завантаження файлів.
- Зчитування з датчиків.

Суб’єкти інформаційних відносин в ІТС:

- організація власник інформаційних ресурсів;
- структурні підрозділи організації, що забезпечують експлуатацію ІТС;
- посадові особи та співробітники структурних підрозділів організації, як користувачі ІТС у відповідності із службовими обов’язками;
- підприємства, державні органи та установи - учасники інформаційної взаємодії з ІТС.
- юридичні та фізичні особи, інформація про яких накопичується, зберігається та обробляється в ІТС;
- юридичні та фізичні особи, задіяні в процесі створення та функціонування ІТС:
  - розробники компонентів ІТС,
  - обслуговуючий персонал,
  - організації, що надають послуги у сфері захисту інформації тощо.

Порушник – це особа, яка може одержати доступ до роботи з включеними до складу ІТС засобами (апаратними і програмними).

Кіберзлочинці:

- Аматори.
- Хакери.
- Конкуренти.
- Державні організації.
- Інсайдери.

Мотиви кіберзлочинів:

- Для винагороди.
- Для отримання вигоди.
- Протест.
- Війна.
- Тероризм.

Рівень	Можливості порушника
1	Запуск фіксованого набору завдань (програм), що реалізують заздалегідь передбачені функції обробки інформації
2	Створення і запуск власних програм з новими функціями обробки інформації
3	Управління функціонуванням ІТС, тобто впливом на базове програмне забезпечення системи і на склад і конфігурацію її устаткування
4	Увесь обсяг можливостей осіб, що здійснюють проектування, реалізацію і ремонт апаратних компонентів ІТС, аж до включення до складу ІТС власних засобів з новими функціями обробки інформації

Рівень	Знання порушника
1	Володіють інформацією про функціональні особливості АС, основні закономірності формування в ній масивів даних та потоків запитів до них, вміють користуватися штатними засобами
2	Володіють високим рівнем знань та досвідом роботи з технічними засобами системи та їх обслуговування
3	Володіють високим рівнем знань у галузі обчислювальної техніки та програмування, проектування та експлуатації АС
4	Володіють інформацією про функції та механізм дії засобів захисту

Використовувані порушником методи
Виключно агентурні методи
Пасивні технічні засоби перехоплення інформаційних сигналів
Виключно штатні засоби АС або недоліки проектування КСЗІ для реалізації спроб НСД
Способи і засоби активного впливу на АС, що змінюють конфігурацію системи (підключення додаткових або модифікація штатних технічних засобів, підключення до каналів передачі даних, впровадження і використання спеціального ПЗ тощо).

Порушники за місцем дії
Без доступу на контрольовану територію
З доступом на контрольовану територію, але без доступу до технічних засобів АС
З доступом до робочих місць користувачів АС
З доступом до місць накопичення і зберігання даних (баз даних, архівів)
з доступом до засобів адміністрування АС і засобів керування КСЗІ

КЛАСИФІКАЦІЯ ЗАГРОЗ

За об'єктами
- Персонал
- Матеріальні і фінансові цінності
- Інформаційні ресурси

За спрямованістю
- Конфіденційність
- Цілісність
- Доступність
- Спостережність

За величиною збитку
- Граничний
- Значний
- Незначний

З причин появи
- Випадкові
- Умисні

За відношенням до об'єкту захисту
- Внутрішні
- Зовнішні

За характером дії
- Активні
- Пасивні

За імовірністю виникнення
- Дуже імовірні
- Імовірні
- Малоймовірні

Класифікація загроз безпеки ІТС (можливостей впливу на ІТС, які прямо або непрямо завдають збитку її безпеки):

1. За *аспектом інформаційної безпеки*, проти якої вони спрямовані:
- загрози цілісності інформації;
- загрози конфіденційності;
- загрози доступності;
- загрози спостереженості та керованості ІТС.

2. За *природою виникнення*:
- природні загрози;
- штучні загрози.

3. За *ступенем навмисності прояву*:
- загрози, викликані помилками або халатністю персоналу;
- загрози умисної дії.

4. За *безпосереднім джерелом загроз*:
- природне середовище;
- людина;
- санкціоновані програмно-апаратні засоби;
- несанкціоновані програмно-апаратні засоби.

5. За *положенням джерела загроз*:
- поза контрольованої зони ІТС;
- в межах контрольованої зони ІТС,

6. За *ступенем дії на ІТС*:
- пасивні загрози;
- активні загрози.

7. За *етапами доступу користувачів або програм до ресурсів ІТС*:
- загрози, що проявляються на етапі доступу до ресурсів ІТС;
- загрози, що проявляються після дозволу доступу до ресурсів ІТС.

8. За *способом доступу до ресурсів ІТС*:
- загрози з використанням стандартного шляху доступу;
- загрози з використанням прихованого нестандартного шляху доступу.

Причини випадкових дій:

- аварійні ситуації із-за стихійних лих і відключень електроживлення;
- відмови і збої апаратури;
- помилки в програмно-апаратном забезпеченні;
- перешкоди в лініях зв'язку із-за дій зовнішнього середовища;
- ненавмисне пошкодження носіїв інформації;
- неправомірна зміна режимів роботи АС, які здатні призвести до незворотних змін у системі (форматування носіїв інформації);
- неумисне зараження вірусами;
- невиконання вимог захисту;
- помилки під час введення даних в систему;
- розголошення конфіденційних відомостей, атрибутів розмежування доступу, втрата атрибутів;
- впровадження і використання забороненого політикою безпеки ПЗ (ігрові програми);
- некомпетентне застосування засобів захисту.

Умисні загрози:

- порушення фізичної цілісності АС;
- порушення режимів функціонування (виведення з ладу) систем життєзабезпечення АС (електроживлення, заземлення, охоронної сигналізації, вентиляції та ін.);
- порушення режимів функціонування АС (обладнання і ПЗ);
- впровадження і використання комп’ютерних вірусів, закладних (апаратних і програмних) і підслуховуючих пристроїв, інших засобів розвідки;
- використання засобів перехоплення побічних електромагнітних випромінювань і наводок, акусто-електричних перетворень інформаційних сигналів;
- використання (шантаж, підкуп) персоналу АС;
- крадіжки носіїв інформації, виробничих відходів (роздруків, записів);
- несанкціоноване копіювання носіїв інформації;
- одержання атрибутів доступу з наступним їх використанням для маскування під зареєстрованого користувача;
- неправомірне підключення до каналів зв’язку, перехоплення даних, що передаються, аналіз трафіку;
- впровадження і використання забороненого політикою безпеки ПЗ, щоб одержати доступ до критичної інформації.

Інсайдер – це людина, допущена до роботи з інформацією, яка призначена для строго обмеженого кола осіб.

Способи обробки ризиків:

- Уникнути (Avoid).
- Знизити, пом'якшити (Mitigations).
- Передати (Transfer)
  (аутсорс, страхування, розподіл повноважень).
- Прийняти (Accept).

Поняття допустимого для організації ризику (Risk Tolerance).

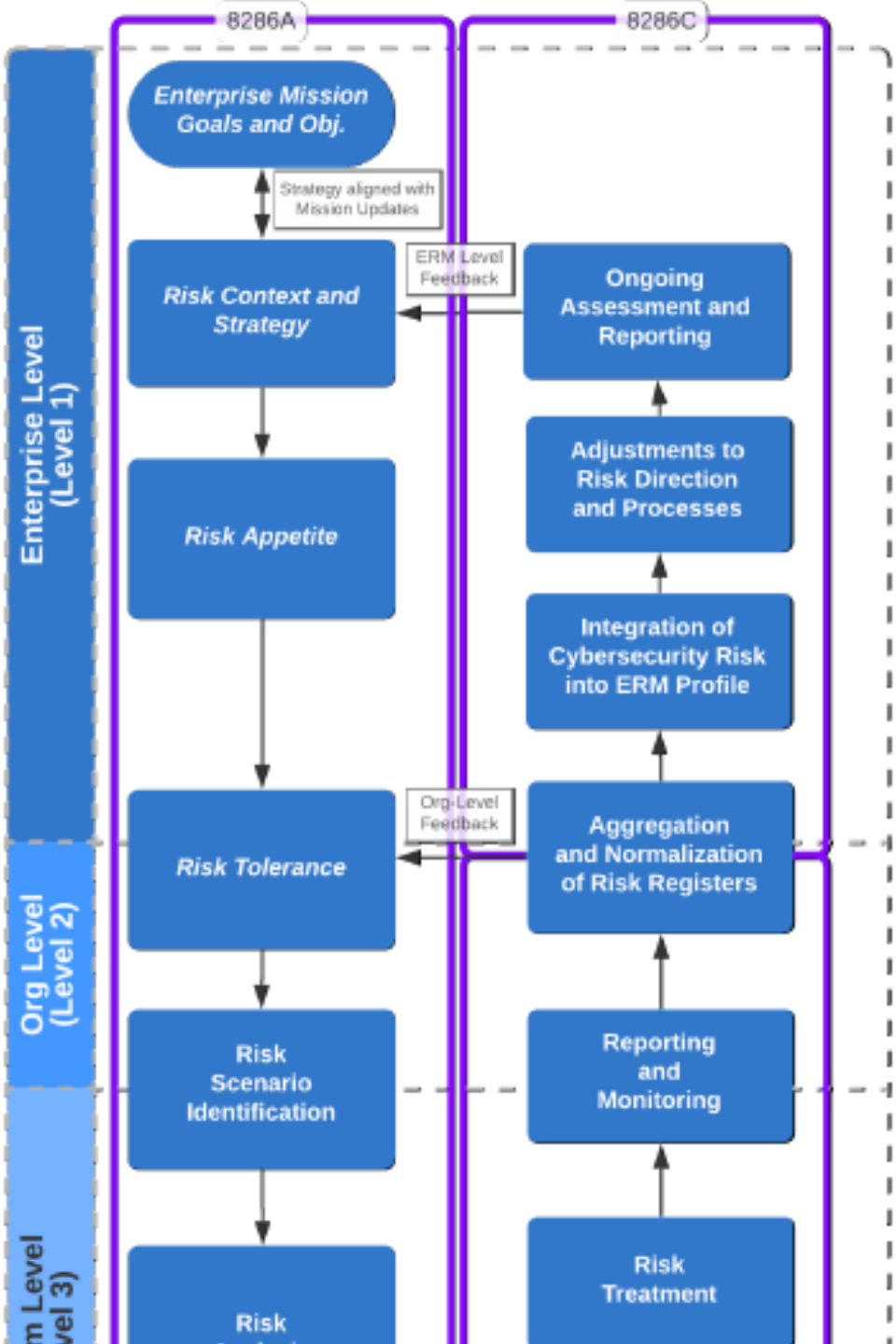
Аналіз ризиків:

- Кількісний:

SLE (Одиночна втрата) = (Вартість активу) x (Кзбитку)
ARO - річна ймовірність
Щорічна втрата = SLE x ARO

- Якісний

	Часто 5	Можливо 4	Випадково 3	Рідко 2	Невірогідно 1
Катастрофічно 4	20	15	12	8	4
Критично 3	15	12	9	6	3
Несуттєво 2	10	8	6	4	2
Незначно 1	5	4	3	2	1



NISTIR 8286B
Prioritizing Cybersecurity Risk for Enterprise Risk Management
Визначення пріоритетів ризиків кібербезпеки для управління ризиками підприємства

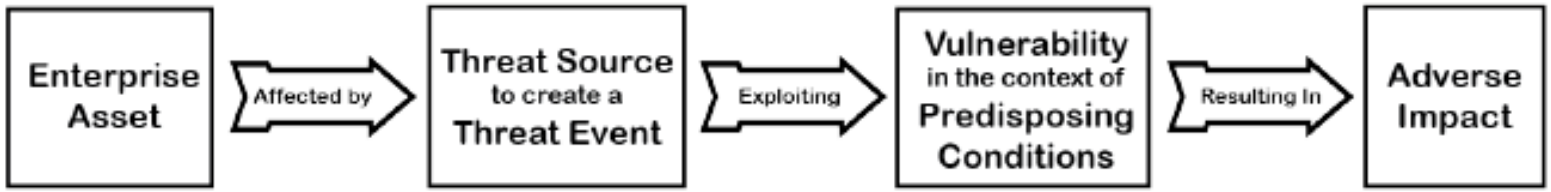


Figure 3: Inputs to Risk Scenario Identification

Notional Cybersecurity Risk Register												
ID	Priority	Risk Description	Risk Category	Current Assessment			Risk Response Type	Risk Response Cost	Risk Response Description	Risk Owner	Status
				Likelihood	Impact	Exposure Rating					
1											
2											
3											
4											
5											
Continually Communicate, Learn, and Update											

Figure 4: Notional Cybersecurity Risk Register Template

Cybersecurity Risk Register (CSRR)

ID	Priority	Risk Description	Risk Category	Current Assessment		
				Likelihood	Impact	Exposure Rating
2	1	External malicious actor deploys a ransomware attack causing unavailability of financial systems	System and Information Integrity (SI)	0.9	0.9	.81
5	2	Portable workstation containing digital designs is lost (e.g., left on an airplane)	System and Communication Protection (SC)	0.8	0.5	.40
3	3	A natural disaster disrupts communications circuits impeding customer access	Contingency Planning (CP)	0.4	0.3	.12
1	4	A computer tower is stolen from the reception area	Physical and Environmental Protection (PE)	0.75	0.1	.075
4	1	Human Resource Management Systems move to a cloud solution, providing in-house IT infrastructure savings and improving availability.	System and Services Acquisition (SA)	0.5	0.5	.25

Figure 6: Excerpt from a Notional Cybersecurity Risk Register (from NISTIR 8286)

Table 1: Response Types for Negative Cybersecurity Risks

Type	Description
Accept	Accept cybersecurity risk within risk tolerance levels. No additional risk response action is needed except for monitoring.
Transfer	For cybersecurity risks that fall outside of tolerance levels, reduce them to an acceptable level by sharing a portion of the consequences with another party (e.g., cybersecurity insurance). While some of the financial consequences may be transferrable, there are often consequences that cannot be transferred, like the loss of customer trust. (Sometimes referenced as Sharing.)
Mitigate	Apply actions (e.g., security controls discussed in Section 3.5.1) that reduce the threats, vulnerabilities, and impacts of a given risk to an acceptable level. Responses could include those that help prevent a loss (i.e., reducing the probability of occurrence or the likelihood that a threat event materializes or succeeds) or that help limit such a loss by decreasing damage and liability.
Avoid	Take actions to eliminate the activities or conditions that give rise to risk. Avoiding risk may be the best option if there is no cost-effective method for reducing the cybersecurity risk to an acceptable level. The cost of the lost opportunity associated with such a decision should be considered as well.

ID	Priority	Risk Description	Risk Category	Current Assessment			Risk Response Type	Risk Response Cost	Risk Response Description	Risk Owner
				Likelihood	Impact	Exposure Rating				
17	L	Personal computer (PC) is stolen from the reception area.	Physical and Environmental Protection (PE)	75%	$2,000	$1,500	Accept	$0	No response required	Kira Caldwell
25	H	Unauthorized connection to manufacturing plant, altering 3D plans, corrupts production goods.	Access Control (AC)	37%	$1M	$370K	Avoid	$0	No response required	Jemima Daugherty (Carly Hickman - backup)
21	M	A natural disaster disrupts communications circuits impeding customer access.	Contingency Planning (CP)	10%	$1.5M	$150K	Transfer	$150K	Purchase cybersecurity insurance to reimburse downtime	Mark Winters
8	M	A tornado disrupts headquarters communications circuits impeding e-commerce traffic.	Contingency Planning (CP)	10%	$1.5M	$150K	Mitigate	$250K	Move circuits into underground conduit. (See RDR notes for justification)	Mark Winters
11	H	Attacker exploits web server flaw, deploys a ransomware program on critical financial reporting system.	System and Information Integrity (SI)	90%	$4.1M	$3.7M	Mitigate	$1.9M	Re-engineer networks with separation; improve backups; improve patching; update policies	Jeffrey Contreras

Figure 10: Example Risk Responses in the CSRR

Політики безпеки:

- Встановлюють правила.
- Визначають:
  - Активи, що потрібно захищати,
  - Можливих порушників,
  - Загрози,
  - Ризики та їх оцінка,
  - Методи пом’якшення ризиків,
  - Дії у випадку порушення безпеки,
  - Методи відновлення,
  - Наслідки.
- Узгоджують в:
  - Роботі,
  - Придбанні,
  - Обслуговуванні.
- Регламентують:
  - Навчання,
  - Тренування.

Політика безпеки включає політики:

- Ідентифікації і авторизації.
- Управління доступом.
- Паролів (зміна, вимоги).
- Використання ресурсів.
- Криптографічного захисту.
- Віддаленого доступу.
- Мережевого обслуговування.
- Резервування.
- Обробки інцидентів.
- Відновлення.
- Служб, процедур та функцій.
- Фізичної безпеки.
- Інтернет доступу.
- Адміністрування доступу.
- Антивірусного/антишпигунського захисту.
- Управління ризиками.
- Підбору персоналу.
- Тренування, навчання.
- Окремих компонентів системи.
- Проблемно-орієнтована.

Основні складові політики безпеки (NIST):

- Мета.
- Сфера застосування (які ресурси захищає (обладнання, АЗ/ПЗ, інформацію та персонал)).
- Обов'язки.
- Відповідність.

Політика безпеки, як правило, складається з таких розділів:

1. Загальні положення (призначення / правова основа).
2. Об’єкти захисту:
   - категорії активів, які підлягають захисту.
   - структура, склад і розміщення об’єктів захисту та зв’язки між ними,
   - стратегія системи комплексного захисту інформації:
     - захисна,
     - наступальна,
     - попереджувальна.
3. Мета та основні завдання забезпечення безпеки.

Політика безпеки, як правило, складається з таких розділів:

3. Основні загрози безпеці інформації організації:
   - природні (об'єктивні) / штучні (суб’єктивні).
   - навмисні / ненавмисні.
5. Модель можливих порушників:
   - опис порушника,
   - його мотивації,
   - кваліфікації,
   - можливі дії.
6. Витік інформації технічними каналами:
   - аналіз існуючих / можливих технічних каналів витоку інформації,
   - пасивні / активні способи протидії.

Політика безпеки, як правило, складається з таких розділів:

7. Методи та засоби забезпечення задекларованого рівня захищеності:
   - регламентація/розмежування доступу (в приміщення/до інформаційних ресурсів),
   - порядок обслуговування/модифікації АЗ/ПЗ,
   - методи забезпечення цілісності АЗ/ПЗ,
   - методи підбору/підготовки персоналу,
   - відповідальність за порушення порядку,
   - засоби забезпечення інформаційної безпеки (фізичні/технічні),
   - засоби захисту,
   - засоби ідентифікації/автентифікації користувачів,
   - засоби контролю/реєстрації подій,
   - криптографічні засоби захисту.
8. Порядок внесення змін та доповнень.

Тема 4. Несанкціонований доступ до інформації і способи його здійснення

Питання:

- Способи здійснення НСД.
- Модель способів НСД до джерел інформації.
- Основні задачі НСД.
- Основні канали НСД.
- Загальні ризики інформаційної безпеки.
- Соціальна інженерія.
- Захист від соціальної інженерії.
- Шкідливе програмне забезпечення (ШПЗ).
- Канали поширення вірусів.
- Захист від ШПЗ.
- Типи мережевих атак.
- Загрози при безпровідному доступі до локальної мережі.
- Комбіновані атаки.
- Тенденції та сценарії розвитку ІТ-загроз.

Несанкціонований доступ (НСД) – це доступ до інформації з використанням засобів, включених до складу ІТС, що порушує встановлені правила розмежування доступу (ПРД).

НСД може здійснюватися:

- з використанням штатних засобів (сукупності програмно-апаратного забезпечення), що входять у затверджену конфігурацію ІТС;
- з використанням програмно-апаратних засобів, включених до складу ІТС порушником.

Загальні ризики інформаційної безпеки:

- Атаки соціальної інженерії (Social engineering).
- Розширені постійні загрози (Advanced persistent threats, APT) - отримують доступ до ваших систем і залишаються на них протягом тривалого часу.
- Інсайдери (Insider).
- Шкідливе програмне забезпечення ШПЗ (Malware).
- Розподілена відмова в обслуговуванні (DDoS).
- Атака "людина посередині" (MitM).

Соціальна інженерія:

- Видавання себе за когось іншого (Pretexting).
- Послуга за послугу (Quid pro quo).
- Приманювання (Baiting).
- Серфінг через плече (Shoulder surfing).
- Дайвінг у смітнику.
- Містифікація / розіграш.
- Несанкціоноване проникнення на територію (Piggybacking).
- Вербування.

Захист від соціальної інженерії:

- Не надавати / залишати конфіденційну інформацію / облікові дані.
- Не відкривати електронні листи з ненадійних джерел.
- Не натискати на привабливі ненадійні посилання.
- Не викладати робочу інформацію в соцмережах.
- Не використовувати робочі паролі в інших місцях.
- Звертати увагу на несанкціоновані/автоматичні завантаження.
- Політика знищення інформації.
- Захист / блокування екрану.
- Повідомляти про підозрілих осіб.

ШПЗ Шкідливе програмне забезпечення (Scareware, Malware):

- Віруси (Virus).
- Черв’яки, хробаки (Worm).
- Троянські коні (Trojan).
- Вимагачі (Ransomware).
- Шпигунське ПЗ (Keylogger).
- Рекламне ПЗ (Adware).
- Псевдоантивіруси.
- Логічні бомби (Logic Bomb).
- Backdoor та Rootkit.
- ШПЗ для майнінгу (Cryptomining malware).
- ШПЗ для ботнету (Botnet malware).

Віруси поширюються через:

- Змінні носії.
- Заражені веб-сайти.
- «Безкоштовне» ПЗ.
- Інфіковані хости.
- Вкладення електронної пошти.
- Беб-браузер з вразливостями.
- Файлобмінники.

Захист від ШПЗ:

- Антивірус.
- Анти-зловмисне ПЗ (NGAV).
- Резервне копіювання (Backup).
- Оновлення (Update).
- Безпечна електронна пошта.
- NGFW (Next-Generation Firewall), IPS, SIEM.
- Розподіл мережі (VLAN, DMZ).
- Навчання персоналу.

Основні категорії мережевих атак

Атаки доступу

- Підслуховування (Sniffing)
- Перехоплення (Hijacking)
- Перехвоплення сеансу (Session)

Атаки модифікації

- Зміна даних
- Додавання даних
- Видалення даних

Атаки типу «відмова в обслуговуванні»

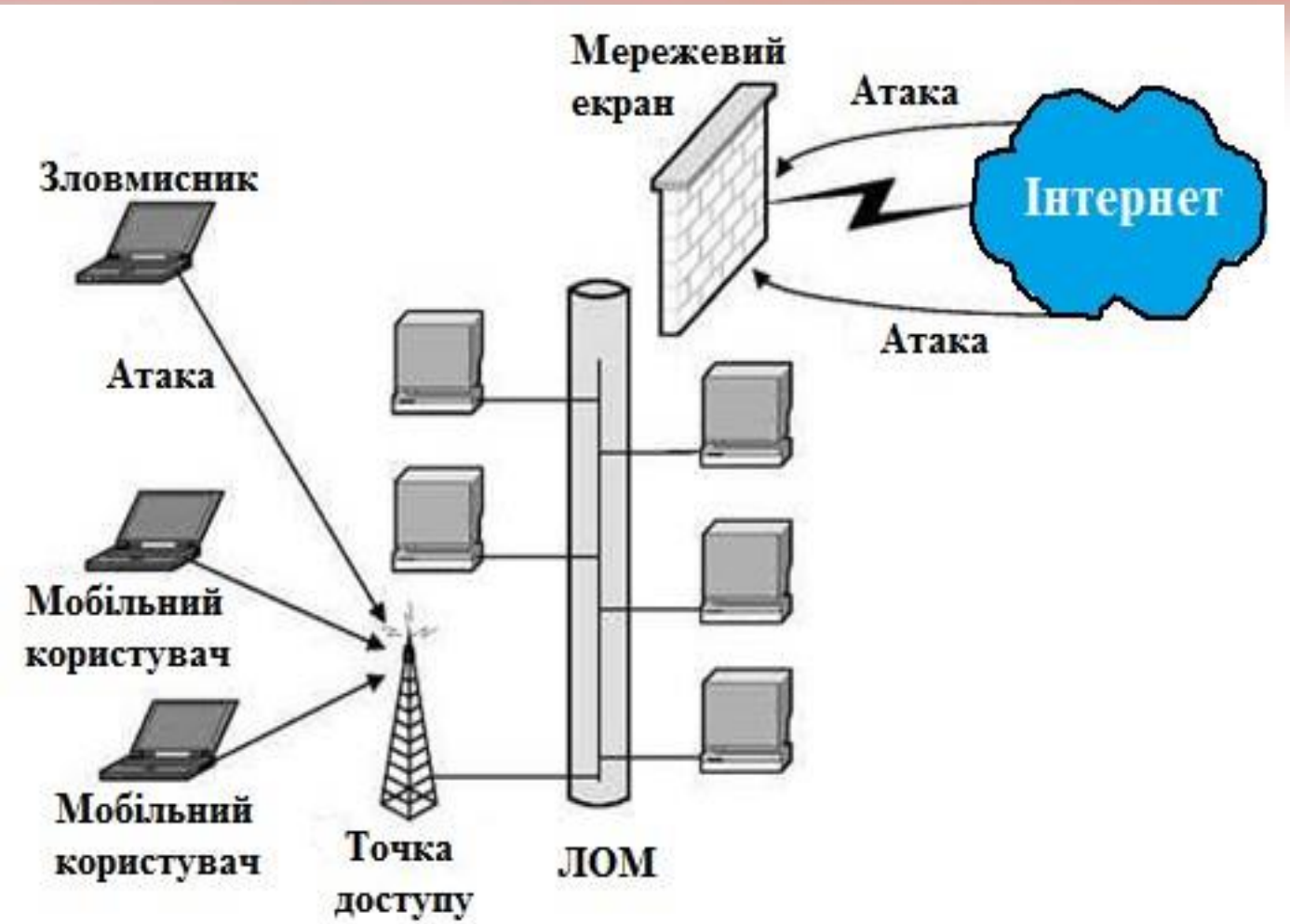
- Відмова в доступі до інформації
- Відмова в доступі до застосувань
- Відмова в доступі до системи
- Відмова в доступі до засобів зв'язку

Комбіновані атаки

- Підміна довіреного суб'єкта
- Посередництво
- Посередництво в обміні незашифрованими ключами
- Атака експлойта
- Парольні атаки
- Мережева розвідка
- Фішинг (Phishing)
- Фарминг (Pharming).
- Застосування ботнетів
- Розсилка спаму

Комбіновані атаки:

- Підміна довіреного суб’єкта (Spoofing) (MAC, IP, DNS, DHCP).
- Посередництво (Man-in-the-middle (MitM)).
- Посередництво в обміні незашифрованими ключами (Sniffer).
- Атака експлойта (XSS, SQL, XXE, OS injection, API).
- Викрадення сеансу (Session hijacking).
- Парольні атаки (brute force, dictionary).
- Мережева розвідка.
- Фішинг (Phishing).
- Голосовий фішинг.
- СМС фішинг (Смішинг (SMishing)).
- Фарминг (Pharming).
- Whaling.
- Отруєння браузера та плагінів.
- Rooting & Jailbreaking.
- Атака нульового дня.
- DoS, DDoS, (ICMP, Botnet, DNS, DHCP)
- Спам.
- Зловживання пошуковою оптимізацією (SEO Poisoning).
- «Злий близнюк» (Evil Twin) використовує несанкціоновані точки доступу (Rogue Access Points).
- Глушіння радіочастот (RF faming)
- Передача несанкціонованих повідомлень через Bluetooth (Bluejacking).
- Підключення до Bluetooth з метою крадіжки (Bluesnarfing).
- Пристрої IoT:
  - камери,
  - комп'ютерна система автомобілів (гальма, двигун, замки, капот, вентиляція, панель приладів),
  - електрокардіостимулятори, інсулінові помпи, імплантовані кардіо-дефібрилятори.
- Вразливості IoT:
  - Безпека паролів (кофемашина - пароль мережі wi-fi),
  - Шифрування даних.



Структура безпровідної локальної мережі WLAN

Основні уразливості і загрози безпровідних мереж

- Мовлення радіомаяка
- Виявлення WLAN
- Підслухову-вання
- Фальшиві точки доступу в мережу
- Атаки типу «людина-в-середині»
- Відмова в обслуговуванні
- Анонімний доступ в Інтернет

Тема 5. Методи, засоби та заходи захисту інформації в ІТС від НСД

Питання:

- Основні принципи забезпечення захисту інформації від НСД.
- Планування захисту і керування системою захисту.
- Концепція матриці доступу.
- Довірче і адміністративне керування доступом.
- Забезпечення персональної відповідальності.
- Основні принципи реалізації програмно-технічних засобів захисту інформації в ІТС від НСД.
- Комплекс засобів захисту (КЗЗ) та вимоги до нього.
- Концепція диспетчера доступу.
- Ядро захисту.
- Ядро та функції NIST Cybersecurity Framework.
- Класифікація сповіщень.
- КЗЗ, що мають експертний висновок про відповідність до вимог ТЗІ.
- Архітектура захисту.
- Інформаційна безпека малого бізнесу.
- Технічні заходи безпеки.
- На кінцевих точках, в мережі, у веб-браузерах.
- На мобільних пристроях.
- Фізична безпека.

Захист від НСД – це діяльність, спрямована на забезпечення додержання правил розмежування доступу шляхом створення і підтримки в дієздатному стану системи заходів із захисту інформації.

Основні **принципи забезпечення захисту інформації від НСД**:

- планування захисту;
- керування доступом;
- забезпечення послуг безпеки.

При **плануванні** дій слід враховувати порядок створення КСЗІ:
- *аналіз об'єкта захисту і можливих загроз*;
- *оцінка ризиків*;
- *вироблення заходів захисту*;
- *формулювання або коригування політики безпеки*;
- *розробка плану захисту*.

Основні **принципи керування доступом**:
- безперервний захист;
- наявність атрибутів доступу
  (унікальний ідентифікатор, що визначає його права доступу);
- довірче і адміністративне керування доступом;
- забезпечення персональної відповідальності.

КЗЗ (мають експертний висновок про відповідність до вимог ТЗІ):

- АС класу «1»: Лоза-1, Гриф v4;
- АС класу «2»: Гриф v4, Гриф-Мережа;
- АС класу «3»: Гриф v4,

ESET, McAfee, Symantec, Check Point (Endpoint Protection),
ESET, Cisco, Fortinet, FossDoc (ел. пошта/web),
iDoc, АСКОД, CleverForms, Megapolis.DocNet, ДОК ПРОФ ВЕБ, FossDoc, e-Docs.Platform (ел. документообіг),
Symantec, GTB, Safetica (DLP),
Microsoft SQL Server, Oracle (БД),
Cisco Webex (відеоконференції),
Cisco, Huawei, Hewlett Packard, Fortinet (мережевий захист),
Fortinet (WiFi Protection),
Check Point (DDoS Protection).

Технічні заходи безпеки

- Планування та сегментація мережі (VLAN, DMZ, сервера, брандмауери, бездротові точки, мобільні пристрої).
- Зміна даних за замовченням (пароль, логін, SSID, IoT).
- Вимкнення трансляцію SSID.
- Вимкнення UPnP.
- Вимкнення ping-сканування.
- Керування віддаленим доступом (Remote Desktop/Assistance).
- Вимкнення автовідтворення (USB, CD/DVD).
- Фільтрація незвичайних запитів.
- Блокування зовнішніх запитів (Білі/чорні списки):
  - MAC,
  - IP,
  - URL,
  - протоколи,
  - для введення,
  - ключові слова.

- Перевірка значень (валідація):
  - Обов’язковість введення,
  - Маска,
  - Діапазон значень,
  - Розмір,
  - Формат,
  - Контрольна цифра,
  - Затвердження іншою особою,
  - Ліміт на кількість змін.
- IP-адреси визначати статично (без DHCP).
- Фільтрація електронної пошти (ESA).
- Шифрування:
  - даних (EFS, BitLocker, BitLocker TO GO),
  - трафіку (SSL/TSL, WPA2, SSH, в IoT),
  - ключів (KHMAC),
  - паролів (SHA 256/384/512).

- VPN (IKE, IPSec).
- Проксі-сервер.
- Закриття:
  - Портів,
  - Служб,
  - Облікових записів,
  - Інтерфейсів,
  - Доступу до каталогів/файлів.
- Контроль доступу:
  - Принцип найменших привілеїв,
  - Зменшення кількості привілейованих облікових записів.
- Криптографічна аутентифікація.
- Політика паролів (BIOS, ПК, мережеві):
  - Вимоги до складності,
  - Передавання,
  - Зберігання,
  - Термін дії.

- Багатофакторна аутентифікація.
- Використання «Солі».
- Хешування (SHA 256).
- Цифрові підписи/сертифікати (алгоритми DSA, RSA, ECDSA).
- Antihammer/Anti brute force механізми.
- Тайм-аут очікування та блокування, початок роботи з логування.
- Обмежити час доступу до:
  - ПК,
  - Даних,
  - Мережі,
  - Інтернету.
- Екран конфіденційності.
- Функції веб-браузерів (Tor):
  - Перегляд InPrivate,
  - Блокування спливаючих вікон (pop-up, pop-under),
  - Видалення історії,
  - SmartScreen (список завідомо шкідливих сайтів/файлів),
  - Фільтрація ActiveX (підтвердження для кожного сайту).

- Налаштування на мобільних пристроях:
  - PIN,
  - Графічний пароль,
  - Біомертична аутентифікація,
  - Блокування коли виходить за визначені межі,
  - Політика підключення до мобільних точок доступу,
  - Видалити / вимкнути режим налагодження,
  - Моніторинг ресурсів:
    - Батарея,
    - Використання пам'яті,
    - Мережевий трафік,
    - Послуги (служби).
  - Виявляти підозрілі програми, які вимагають прав,
  - Процедури відкликання (функція для мобільних додатків: віддалене відкликання).
  - Локатор – ПЗ для знаходження пристрою.
    - Apple Find Me,
    - Android Device Manager.

- Відключення Bluetooth,
- Облік (журнали):
  - Отримання / припинення доступу,
  - Час,
  - Невдалі спроби (легування, доступу, зміни, видалення).
- Моніторинг (IDS, IPS, HIDS, SIEM, апаратні t, живлення, стан).
- Оновлення.
- Системне резервування (RAID, інше обладнання).
- Розподіл навантаження (RAID, інше обладнання).
- Резервне копіювання (Mobil Device Management (MDM)) :
  - Частота (повне, часткове),
  - Перевірка (цілісність),
  - Зберігання (сховище, політики, шифрування),
  - Безпека (паролі).
- Правильна утилізація АЗ та знищення даних (Розмагничування, низкорівневе форматування).
- Використання хмарних рішень (SaaS, IaaS, PaaS, ITaaS, SECaaS).

- Фізична безпека:
  - Огородження.
  - Ворота.
  - Вікна (решітки).
  - Тамбур-шлюзи (mantraps).
  - Замки (ригельні, електронні, картка, PIN, біометрія):
    - На ворота,
    - На двері,
    - Тросові замки на обладнання.
  - КПП (пост, приміщення).
  - Перешкоди на в’їзді (їжаки, тех. засоби для затримання авто).
  - Перепустки та журнали доступу.
    - Магнітна смуга,
    - Штрих-код,
    - Біометрія.
  - Служба охорони.

- Сигналізація:
  - На проникнення (територію, приміщення),
  - Пожежна,
  - На винос обладнання.
- Відеоспостереження та запис (виявлення руху).
- RFID/GPS-мітки для відстеження та блокування:
  - Обладнання,
  - Перепустки,
  - Робочий одяг.
- Доступ до зон з обмеженим доступом:
  - Серверні,
  - Там де циркулює найбільш критична інформація.
- Короба з комунікаціями.
- Шафи для мережного обладнання.
- Захисні гвинти для фіксації обладнання.

Тема 6. Технічні канали витоку інформації

Питання:

- Технічні канали витоку інформації.
- Причини створення акустичних каналів витоку інформації.
- Канали витоку акустичної інформації з об’єктів інформаційної діяльності (ОІД).
- Класифікація технічних каналів витоку акустичної інформації.
- Технічні засоби обробки інформації (ТЗОІ).
- Контрольована зона (КЗ).
- Небезпечна зона.
- Апаратні закладні пристрої.

Витік – це безконтрольний вихід конфіденційної інформації за межі організації або кола осіб, яким вона довірена. Утворюється за рахунок неконтрольованих фізичних полів (акустичних, світлових, електромагнітних, радіаційних, теплових та ін.)

Технічний канал витоку інформації – фізичний шлях від джерела інформації до порушника, за допомогою якого може бути здійснений НСД до відомостей, що охороняються.

АКУСТИЧНІ КАНАЛИ ВИТОКУ ІНФОРМАЦІЇ

утворюються

За рахунок поширення акустичних (механічних) коливань у вільному повітряному просторі

- Переговори на відкритом просторі
- Відкриті вікна, двері, кватирки
- Вентиляційні канали

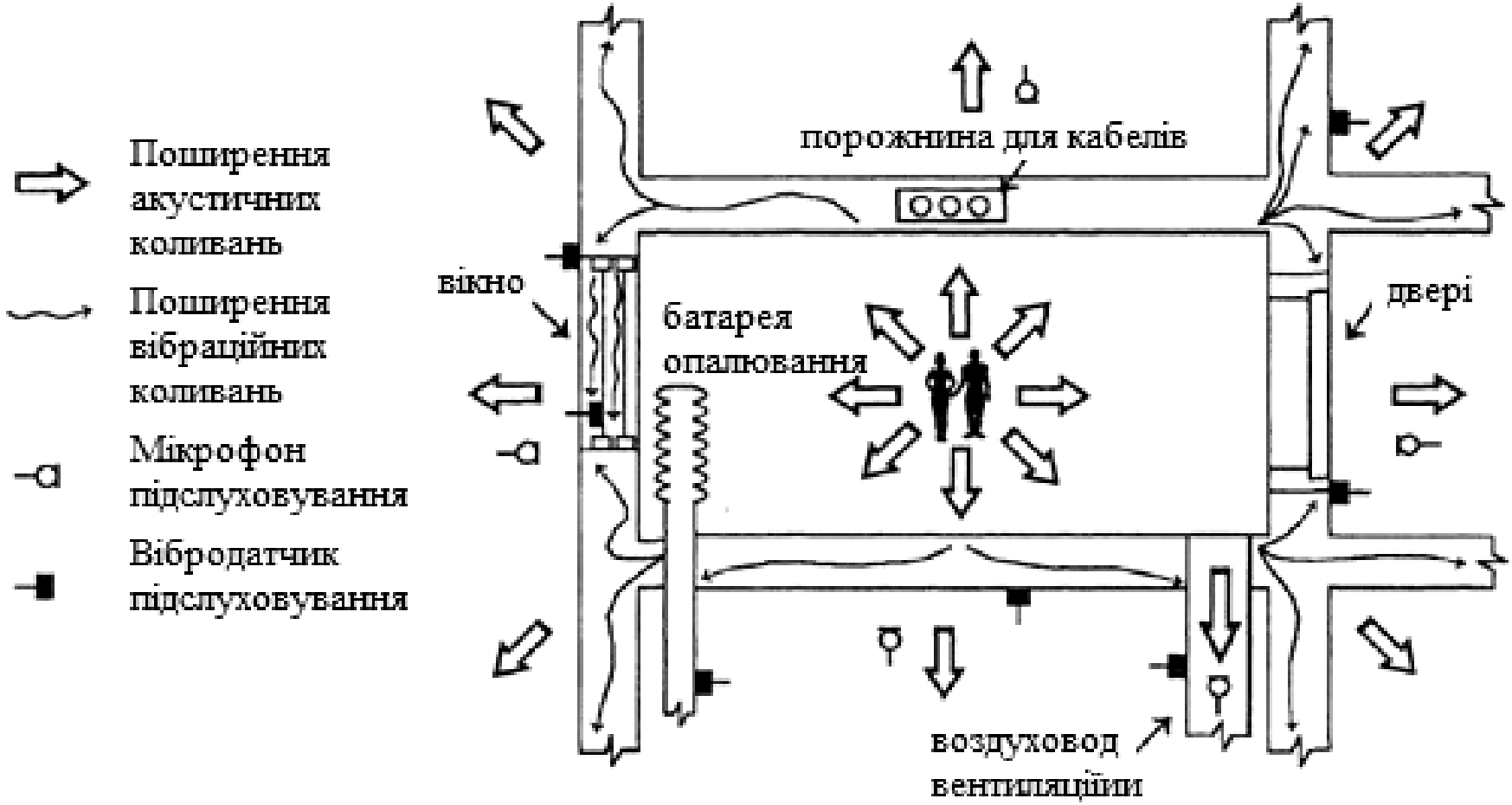
За рахунок дії звукових коливань на елементи і конструкції будівель, викликаючи їх вібрації

- Стіни, стелі, підлоги, вікна, двері, короби вентиляційних систем
- Труби водопостачання, опалювання, кондиціонування та ін.

За рахунок дії звукових коливань на технічні засоби обробки інформації

- Мікрофонний ефект
- Акустична модуляція волоконно-оптичних ліній передачі інформації

Канали витоку акустичної інформації з ОІД



Технічні канали витоку акустичної інформації

Оптико-електронний

- Лазерне зондування шибок

Вібраційні

- Електронні стетоскопами

Повітряні

- Мікрофони з портативними пристроями звукозапису
- Мікрофони з передачею телефонною лінією
- Мікрофони з передачею через мережу Інтернет
- Мікрофони з передачею через wi-fi
- Мікрофони з передачею інформації радіоканалом
- Мікрофони з передачею мережами електроживлення
- Спрямовані мікрофони

Параметричні

- ПЕМВ
- «Високочастотне опромінення»

Технічні засоби обробки інформації (ТЗОІ) обмеженого доступу:

- засоби обчислювальної техніки (ЗОТ) – технічні засоби ІТС, ЕОМ та їх окремі елементи;
- засоби виготовлення і розмноження документів;
- апаратура звукопідсилення, звукозапису, звуковідтворення і синхронного перекладу;
- системи внутрішнього телебачення;
- системи відеозапису і відеовідтворення;
- системи оперативно-командного зв'язку;
- системи внутрішнього автоматичного телефонного зв'язку та ін.

Допоміжні технічні засоби і системи (ДТЗС), які можуть знаходитися в приміщеннях розміщення ТЗОІ:

- системи електроживлення;
- системи кабельного та мобільного Інтернету;
- системи і засоби мобільного і міського телефонного зв'язку;
- системи і засоби передачі даних в системі радіозв'язку;
- системи і засоби охоронної і пожежної сигналізації;
- системи і засоби оповіщення і сигналізації;
- системи і засоби кондиціонування;
- системи і засоби прийому програм телебачення;
- інші технічні засоби і системи.

Контрольована зона (КЗ) – простір (територія, будівля, частина будівлі), в якому виключено неконтрольоване перебування сторонніх осіб (відвідувачів, працівників різних технічних служб, що не є співробітниками організації), а також транспортних засобів.

Межа контрольованої зони – периметр території організації, що охороняється, а також конструкції охороняємої будівлі або частини будівлі, якщо вони розміщені на території, що не охороняється.

Об'єкт інформатизації (ОІ), що захищається, – це сукупність інформаційних ресурсів, що містять відомості обмеженого доступу, ТЗОІ обмеженого доступу, приміщень або об'єктів (будівель, споруд), в яких вони встановлені.

Виділені приміщення (ВП) – приміщення, призначені для ведення закритих переговорів, що містять відомості з обмеженим доступом.

Об'єкти засобів обчислювальної техніки (ЗОТ) – об'єкти інформатизації, на яких обробка інформації здійснюється з використанням комп’ютерної техніки.

Небезпечна зона 1 (*R1*) – простір навколо ТЗОІ, на межі і за межами якого рівень напруги наведеного від ТЗОІ інформативного сигналу не перевищує допустимого (нормованого) значення ($\boldsymbol{U = U_н}$).

Небезпечна зона 2 (*R2*) – простір навколо ТЗОІ, на межі і за межами якого напруженість електромагнітного поля не перевищує допустимого (нормованого) значення ($\boldsymbol{E \le E_н; H \le H_н}$).

Схема технічного каналу витоку інформації в ТЗОІ

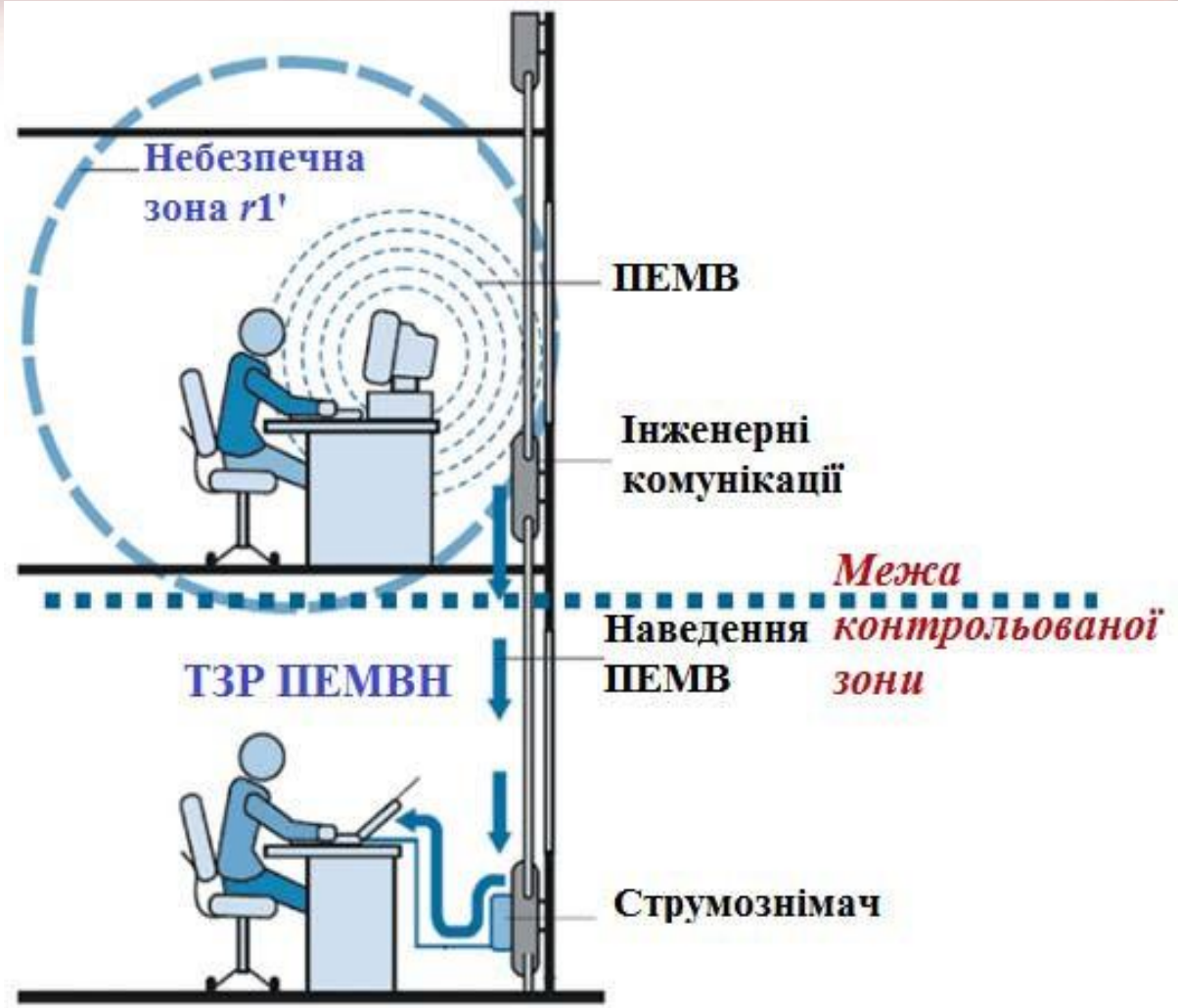
Технічні канали витоку інформації (ТКВІ)

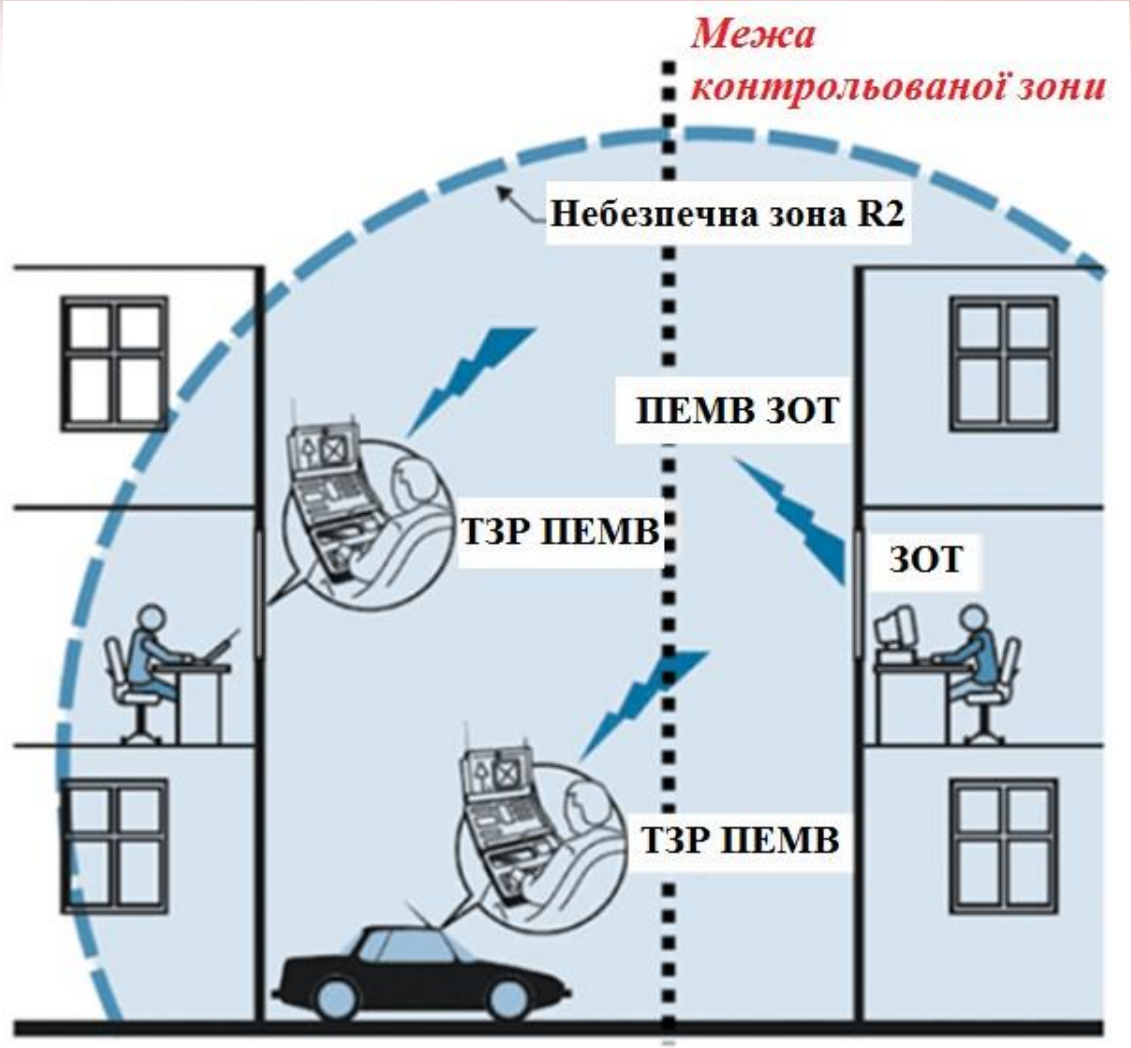
Природні ТКВІ

- Технічні канали витоку інформації, що виникають за рахунок побічних (паразитних) електромагнітних випромінювань (електромагнітні канали витоку інформації)
- Технічні канали витоку інформації, що виникають за рахунок наведень побічних (паразитних) електромагнітних випромінювань (електричні канали витоку інформації)

Спеціально створювані ТКВІ

- Технічні канали витоку інформації, що створюються шляхом "високочастотного опромінення" ТЗОІ
- Технічні канали витоку інформації, що створюються шляхом впровадження в ТЗОІ електронних пристроїв перехоплення інформації (закладних пристроїв)


Небезпечна
зона r1'
ПЕМВ
Інженерні
комунікації
Межа
контрольованої
зони
Наведення
ПЕМВ
ТЗР ПЕМВН
Струмознімач


Межа
контрольованої зони
Небезпечна зона R2
ПЕМВ ЗОТ
ТЗР ПЕМВ
ЗОТ
ТЗР ПЕМВ

Стаціонарний комплекс прийому інформації
Випромінювання апаратної радіозакладки
Мобільний комплекс прийому інформації

Класифікація апаратних закладок, що впроваджуються у ТЗОІ за видом перехоплюваної інформації

- Апаратні закладки для перехоплення зображень, що виводяться на екран монітору
- Апаратні закладки для перехоплення інформації, що вводиться з клавіатури комп'ютера
- Апаратні закладки для перехоплення інформації, що виводиться на периферійні пристрої (наприклад, принтер)
- Апаратні закладки для перехоплення інформації, записуваної на жорсткий диск комп'ютера

Апаратний кейлогер

Клавіатура комп'ютера

Ноутбук із спеціальним ПЗ

Радіоприймальний пристрій

а)

б)

а)

б)

Тема 7. Методи руйнування інформації.

Питання:

- Умисна силова електромагнітна дія.
- Причини умисного руйнування інформації.
- Методи руйнування інформації.
- Завади.
- Навмисні силові впливи (НСВ) та канали його здійснення.
- Класифікація ТЗ НСВ.
- Програмне заглушення обчислювальних систем (ПрЗ ОС).
- Методи заглушення ОС.
- Об'єкти впливу ПрЗ.
- Програмні закладки.

Умисна силова електромагнітна дія на інформацію здійснювана шляхом застосування джерела електромагнітного поля для наведення (генерування) в ІТС електромагнітної енергії з рівнем, що викликає порушення нормального функціонування (збій в роботі) технічних і програмних засобів цих систем.

Причини умисного руйнування інформації:

- порушникові не вдається отримати інформацію технічними каналами;
- порушник прагне приховати сліди несанкціонованого доступу до інформації;
- вандалізм.

Основними **методами руйнування інформації** є:

- застосування завад;
- використання умисних силових електромагнітних впливів на інформаційні об’єкти і апаратно-програмне забезпечення ІТС;
- використання шкідливого програмного забезпечення;
- застосування закладних пристроїв (апаратних і програмних).

Завада (або **перешкода**) – це небажана електрична і (або) магнітна дія на систему або її частину, яка може привести до спотворення інформації, що зберігається, перетворюється, передається або оброблюється.

За *походженням* завади поділяються на:
- *неумисні природного походження* (космічні і атмосферні);
- *неумисні штучного походження*;
- *організовані* (активні та пасивні (екрани, відбивачі)).

Активні завади підрозділяється на:
- *маскуючі* (*загороджувальні*) – створюють шумовий фон у широкій смузі частот, на якому важко виділити корисний сигнал;
- *прицільні* – створюють шумовий фон великої потужності у вузькій смузі часто, енергетично пригнічуючи приймальні пристрої;
- *імітуючі* – підробка корисних сигналів по одному або декількох параметрах.

За *місцем виникнення* завади поділяються на:
- *внутрішні* (шуми, наведення і перешкоди від розузгодження);
- *зовнішні* (промислові (індустріальні), від радіопередавачів, атмосферні та космічні).

Навмисний силовий вплив (НСВ) – це умисне створення різкого сплеску напруги в мережі живлення, по інформаційних дротяних лініях або в ефірі з амплітудою, тривалістю і енергією сплеску, які здатні привести до збоїв в роботі пристрою або до виходу його з ладу.

НСВ за трьома основними **каналами**:

- мережею електроживлення;
- комунікаційними мережами і каналами;
- ефіром з використанням потужних коротких електромагнітних імпульсів.

Класифікація безпровідних ТЗ НСВ

За способом управління

- Автоматичні
- З ручним управлінням
- З дистанційним управлінням

За потужністю (дальністю)

- Малопотужні (до 10 м)
- Потужні (до 100 м)
- Надпотужні (більш 100 м)

За конструкцією

- Стаціонарні
- Мобільні
- Портативні

За принципом дії

- Низькочастотні (до 1 МГц)
  - Генератори з вибуховим стискуванням магнітного поля
  - Магнитодинамічні генератори
- Високочастотні (більш 1 МГц)
  - Магнетрони
  - Клістрони
  - Гіротрони
  - Віркатори
  - Лазери
  - Плазмовопроменеві

Спеціальні та ін. ТЗ НСВ

Програмне заглушення обчислювальних систем (ПрЗ ОС) – це комплекс організаційно-технічних заходів, спрямованих на порушення нормального функціонування ОС шляхом створення їм умисних програмних завад.

Умисні програмні завади (УПрЗ) на логічному рівні є хибними програмами, процедурами, даними.

Метод заглушення ОС:

- процедурними ПрЗ (ШПЗ);
- декларативними ПрЗ (DDoS).

Метод впливу ПрЗ на:

- програмне забезпечення ОС;
- апаратне забезпечення ОС (переналаштування процесора, НЖМД);
- операторів ОС (показ зациклених відео з камер спостереження).

Програмні закладки – це навмисно внесені в ПЗ функціональні об'єкти (програмні коди), які за певних умов ініціюють реалізацію можливостей програмного забезпечення, що не декларується. Як правило, програмні закладки використовують вірусну технологію потайного впровадження, поширення і активізації.

Тема 8. Захист інформації від витоку та руйнування

Питання:

- Організаційні заходи.
- Категоріювання.
- Обов'язкова реєстрація інформації.
- Передача службової і таємної інформації.
- Способи блокування витоку інформації та руйнування.
- Засоби ТЗІ.
- Порядок контролю за станом ТЗІ.
- Акт обстеження на ОІД.
- Служба захисту інформації (СЗІ).
- Завдання, функції, права, обов’язки СЗІ.
- Ролі в системі ІБ (NIST).
- Склад, відповідальність та керівництво СЗІ.
- Взаємодія СЗІ з іншими підрозділами.
- Центр забезпечення безпеки (SOC).
- Елементи SOC.
- Ролі в SOC.
- Мапа доменів кібербезпеки.
- Принципи, порядок збирання цифрових доказів та чого слід уникати.
- План ЗІ.

Організаційні заходи:

- визначити перелік відомостей з обмеженим доступом, що підлягають технічному захисту (визначає власник інформації);
- обґрунтувати необхідність розроблення і реалізації захисних заходів з урахуванням матеріальної або іншої шкоди, яка може бути завдана внаслідок можливого порушення цілісності ІзОД чи її витоку технічними каналами;
- установити перелік виділених приміщень, в яких не допускається реалізація загроз та витік ІзОД;
- визначити перелік технічних засобів, що повинні використовуватися;
- визначити технічні засоби, застосування яких не обґрунтовано службовою та виробничою необхідністю та які підлягають демонтажу;
- визначити наявність задіяних і незадіяних повітряних, наземних, настінних та закладених у приховану каналізацію кабелів, кіл і проводів, що уходять за межі виділених приміщень;
- визначити системи, що підлягають демонтажу, потребують переобладнання кабельних мереж, кіл живлення, заземлення або установлення в них захисних пристроїв.

За результатами обстеження складається **акт** довільної форми **з переліком виконаних заходів (Акт обстеження).**

Категоріювання - сукупність дій зі встановлення категорії об'єкта.

До об'єктив, що підлягають категоріюванню, відносяться:

- ІС та засоби обчислювальною техніки (ЗОТ);
- Технічні засоби де циркулює ІзОД та що не належать до ІС;
- Приміщення, де циркулює ІзОД.

Категорії об'єктів:

1. циркулює інформація, що становить державну таємницю з грифом "*особливої важливості*";
2. циркулює інформація, що становить державну таємницю з грифом "*цілком таємно*";
3. циркулює інформація, що становить державну таємницю з грифом секретності "*таємно*";
4. циркулює службова інформація та ІзОД.

АС (ІТС) класу 1 – одномашинний однокористувачевий комплекс;

АС (ІТС) класу 2 – локалізований багатомашинний багатокористувачевий комплекс, (мережа);

АС (ІТС) класу 3 – розподілений багатомашинний багатокористувачевий комплекс (глобальна мережа).

Категоріювання може бути:

- первинним,
- черговим,
- позачерговим.

У системі здійснюється **обов'язкова реєстрація**:
- результатів ідентифікації та автентифікації користувачів;
- результатів виконання користувачем операцій з обробки інформації;
- спроб несанкціонованих дій з інформацією;
- фактів надання та позбавлення користувачів права доступу до інформації та її обробки;
- результатів перевірки цілісності засобів захисту інформації.

Передача службової і таємної інформації з однієї системи до іншої здійснюється:
- у зашифрованому вигляді або
- захищеними каналами зв'язку.

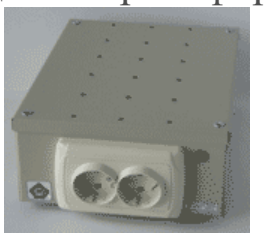
Технічні способи блокування витоку інформації та руйнування:

- відключенням ліній зв`язку ТЗОІ та ДТЗС або встановленням найпростіших схем захисту;
- демонтажем технічних засобів, кабелів, кіл, проводів, що уходять за межі виділених приміщень;
- видаленням за межі виділених приміщень окремих елементів технічних засобів, які можуть бути джерелом виникнення каналу витоку інформації.
- електроживленням систем від трансформаторної підстанції, що знаходиться всередині контрольованої території;
- електроживлення повинно бути стабілізованим;
- заземлення корпусів ТЗОІ;
- розміщення ТЗОІ, по можливості, ближче до центру будинку або в бік найбільшої частини контрольованої території. Складові повинні розміщуватися в одному приміщенні або в суміжних.
- екрановане приміщення;
- фільтрування;
- кабелі в екранувальних конструкціях;
- зменшити довжину паралельного пробігу кабелів різних систем з кабелями, що несуть ІзОД;

Засоби ТЗІ:

- фільтри (ЕМСБІ);

- розділові трансформатори;



- блокіратор бездротового зв’язку (СБ ТЗІ 7-1);

- генератори зашумлення (радіочастотні, на вікна) (DELTA, БАЗАЛЬТ, ЛИВЕНЬ, РІАС, ГШМ, ВИ4);

- екрановані камери.

Порядок контролю за станом ТЗІ

1) Виявлення можливих технічних каналів витоку (проведення спецдосліджень).
2) Вироблення заходів, що забезпечують його приховування.
3) Оцінка достатності й ефективності вжитих заходів захисту.
4) Оперативний контроль за станом технічного захисту каналів витоку інформації.

Технічний канал витоку вважається *захищеним*, якщо сигнал не перевищує встановленого нормативною документацією відношення «інформативний сигнал/шум».

Проводяться вимірювання параметрів інформативного сигналу, виявляється можливість його витоку каналами ПЕМВН.

У випадку перевищення допустимих значень розробляються захисні заходи.

Проводиться оперативний контроль за ефективністю захисту.

Результати контролю (спецдосліджень) оформляються *актом*.